ONE-PAGE BRIEF

Post-quantum cryptography review: signal-desktop @ 17502b9d1a9e

Client: Signal Messenger — public repository (passive review) · Source: github.com/signalapp/Signal-Desktop, commit `17502b9d1a9e` · Reviewed: 2026-10-28 18:29 UTC · Risk profile: Security software vendor

POST-QUANTUM MATURITY

Level 1 of 4

post-quantum code present, not wired

FINDINGS

1 Critical **6** High **3** Medium **0** Low **2** Info

Next step: Wire the existing post-quantum primitive into a critical path (key wrapping or the channel) behind a hybrid construction, and test interoperability.

WHAT MATTERS MOST

Critical QSI-2026-05952	**@storybook/core 8.6.18 is affected by GHSA-f2ph-cmg5-wxc8 (CVE-2026-114125)** What to do: Upgrade to a fixed version (8.6.19).
High QSI-2026-05945	**zod 4.3.6 is affected by GHSA-mrhx-c7xc-m3w5 (CVE-2023-54404)** What to do: Upgrade to a fixed version (4.6.6).
High QSI-2026-05943	**Possible hard-coded secret in ts/state/smart/fun/giphy.preload.ts** preliminary What to do: Move secrets to a secrets manager/environment; rotate the exposed values.
High QSI-2026-05947	**undici 6.29.0 is affected by GHSA-2m5v-pch6-74hx (CVE-2026-109383)** What to do: Upgrade to a fixed version (6.29.1, 7.30.1, 8.12.2).
High QSI-2026-05950	**undici 6.29.0 is affected by GHSA-qrxm-fqhp-jwvm (CVE-2026-87018)** What to do: Upgrade to a fixed version (6.29.1, 7.30.1, 8.12.2).
High QSI-2026-05951	**undici 6.29.0 is affected by GHSA-xjj6-f33q-929c (CVE-2026-109869)** What to do: Upgrade to a fixed version (6.29.1, 7.30.1, 8.12.2).

4 more in the full report.

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 9; each needs checking against the code.

Static review of source code and manifests; files analysed: 2202. No requests were sent to the owner's systems.

Full report, content SHA-256: `7bc698dcb2c9734f1682d4f12713911e942d23cc39434a23f720e6817e6ba212`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.